

Valor 20%

Fecha entrega:

9 de noviembre 8 pm

Grupal

Objetivos de aprendizaje

1. Evaluar, explotar y remediar de forma integral las vulnerabilidades de seguridad en una arquitectura software cliente-servidor mediante la aplicación conjunta del top 10 de OWASP, los controles del marco NIST CSF 2.0 y técnicas avanzadas de manipulación de entradas.
2. Diagnosticar el estado de seguridad de la aplicación mapeando sus vulnerabilidades críticas contra los controles de gobernanza y gestión de riesgos del marco NIST CSF 2.0, para establecer una línea base de impacto técnico y de negocio.
3. Demostrar la viabilidad de los vectores de ataque mediante la construcción de pruebas de concepto (PoC) reproducibles en el cliente y servidor, abarcando escalación de privilegios, inyecciones (OWASP A03), scripts maliciosos (XSS) y alteración de registros de auditoría (*Audit Poisoning*).
4. Implementar las correcciones a nivel de código fuente aplicando prácticas de codificación segura, sanitización de entradas, control de accesos y mecanismos defensivos en la arquitectura para mitigar los riesgos identificados sin alterar la operación del sistema.

Instrucciones Generales

Cada equipo selecciona una aplicación web intencionalmente vulnerable basada en una arquitectura cliente-servidor (por ejemplo, Python/Flask o Node.js con un cliente web interactivo). En caso no tener una aplicación, pueden buscar en repositorios públicos, debe tener 4 mínimo módulos o 3 en caso de los grupos de 3.

Estructura de Fases del Proyecto

Fase 1: Diagnóstico y Marco Normalizado (NIST CSF 2.0)

Para garantizar una evaluación exhaustiva, el sistema seleccionado deberá dividirse en 4 módulos principales (Autenticación, Gestión de Usuarios, Operaciones/Transacciones y Logs/Auditoría). **Cada integrante del equipo deberá asumir la responsabilidad individual de un módulo** y ejecutar las siguientes actividades:

- **Mapeo del Módulo Asignado contra NIST CSF 2.0:** Evaluar de forma individual los componentes, endpoints y lógica de negocio de su módulo frente a las subcategorías del marco NIST CSF 2.0.
- **Inventario de Activos e Impacto de Riesgo (*GOVERN* e *IDENTIFY*):** Identificar los activos críticos de su módulo (datos procesados, servicios, bases de datos) y determinar el impacto operacional y de negocio en caso de un incidente de seguridad.
- **Establecimiento de la Línea Base de Controles:** Definir los controles de seguridad mínimos requeridos (*PROTECT*, *DETECT*) para su módulo específico antes de iniciar la auditoría técnica y fase de explotación.
- **Consolidación Grupal:** Integrar las evaluaciones individuales en una **Matriz General de Gobernanza del Sistema**, asegurando la coherencia entre los 4 módulos evaluados.

Entregable:

1 documento de Matriz General de Gobernanza del Sistema: Documento consolidado que integra las evaluaciones individuales de los 4 módulos (o 3 en caso de los equipos de 3), incluyendo el mapeo contra NIST CSF 2.0, el inventario de activos, el análisis de impacto de riesgo (*GOVERN* e *IDENTIFY*) y la línea base de controles de seguridad de la Fase 1.

Fase 2: Evaluación Ofensiva y Explotación (OWASP) Los estudiantes documentan mediante una Proof of Concept (PoC) de cada módulo asignado los hallazgos en tres vectores:

- 1. Explotación de Software de Servidores:**
 - *Puntos de Inyección & Patrones de Ataque:* Explotación de Inyección SQL/Command Injection (OWASP A03: Injection).
 - *Escalación de Privilegios & Explotación de la Confianza:* Explotar desgloses de control de acceso (OWASP A01: Broken Access Control) y desconfianza en tokens JWT o llamadas entre microservicios.
- 2. Explotación de Software en Clientes:**
 - *XSS & Client Scripts Maliciosos:* Ejecución de XSS Stored/Reflected (OWASP A03) para robo de cookies/sesión, manipulación del DOM y ejecución de código no autorizado en el contexto del navegador.
- 3. Alteración de Entrada de Usuario & Detección:**
 - *Creación de Solicitudes Equivalentes:* Ataques CSRF o manipulación de parámetros HTTP (OWASP A08: Software and Data Integrity Failures).
 - *Tracing Code & Audit Poisoning:* Manipulación de entradas para alterar o evadir los registros de auditoría (log injection) e invalidar la *Detección de Intrusos*.

Entregable:

1 Documento de PoCs estandarizado con las PoC de todos los miembros del equipo, cada PoC debe considerar el punto 1, 2 y 3 completo para su módulo.

Fase 3: Remediación, Hardening y Respuesta (NIST Protect & Detect)

En esta fase, **cada integrante del grupo debe asumir la autoría e implementación técnica de las correcciones en el módulo que le fue asignado**, asegurando la trazabilidad individual en el repositorio de código.

- **Protección (*Protect*):** Cada estudiante debe corregir las vulnerabilidades de su módulo aplicando técnicas de codificación segura (*hardening*). Esto incluye la parametrización de consultas, saneamiento/sanitización estricta de entradas, configuración de Content Security Policy (CSP), cookies seguras (`HttpOnly/SameSite`) y la aplicación del principio de menor privilegio en sus endpoints asignados.
- **Detección e Integridad (*Detect*):** Cada estudiante debe corregir la lógica de registros de auditoría de su módulo, garantizando la prevención de *Audit Poisoning* mediante la desinfección de encabezados/parámetros y la implementación de firmas o *tracing* defensivo en sus funciones.

Entregables:

- **1 documento de Matriz de Riesgos NIST CSF Consolidada y actualizada:** Presentación de la matriz actualizada reflejando el riesgo residual post-remediación por cada módulo.

Criterios para la Evaluación del Riesgo Residual

Los estudiantes deben justificar el valor del **Riesgo Residual** mediante la siguiente escala:

- **Alto / Crítico (Riesgo No Aceptable):** El parche soluciona el síntoma pero no la causa raíz, o se pueden saltar las validaciones mediante codificación alternativa. Requiere re-trabajo inmediato.
- **Medio (Riesgo Tolerable):** La vulnerabilidad principal fue eliminada, pero persisten configuraciones laxas (ej. falta de rate limiting en el login remediado).

- **Bajo (Riesgo Aceptado):** El vector de ataque fue completamente neutralizado en el código fuente, la PoC original ya no es ejecutable y el control cumple con la subcategoría de NIST CSF correspondiente.
 - **1 documento de Reporte Técnico de Parches:** Evidencia de los *Pull Requests* (PRs) o *commits* realizados individualmente por cada integrante en el repositorio.

El documento incluye la estructura organizada en secciones:

1. **Ficha del Integrante y Trazabilidad de Git:** Para registrar responsable, módulo, enlace al Pull Request, ID de commits y rama.
2. **Mapeo de la Vulnerabilidad y Parche:** Asociando el fallo a OWASP Top 10, NIST CSF 2.0 y archivos/líneas de código afectadas.
3. **Comparativa de Código (Diff de Remediación):** Bloque visual en formato Diff (antes vs después).
4. **Verificación de No-Reincidencia (Prueba de Regresión):** Sección para validar la PoC corregida y adjuntar evidencias.
 - **Demostración Funcional Individual en Vivo (Video):** Cada estudiante debe grabarse explicando **exclusivamente sobre el repositorio de código y el IDE** los parches y cambios ejecutados en su módulo asignado. Video de máximo 5 minutos por miembro del equipo, pueden subirse como videos individuales.

 **Regla de Evaluación:** Cualquier video que utilice diapositivas (PowerPoint), lectura de documentos o explicaciones teóricas será **descartado de inmediato con nota cero (0)** en ese rubro. La explicación debe ser 100% técnica sobre las líneas de código modificadas.

Consideraciones especiales

1. La profesora estará entregando ejemplos de plantillas para usar, pero son libres de crear sus propios documentos.
2. Si un integrante del equipo no realiza su parte no se penalizará al grupo, sin embargo, en el momento que el integrante incorpore su parte al proyecto, afectará la nota de todos si la solución integral no es de calidad
3. El proyecto debe entregarse como uno solo, no se aceptan documentos separados por persona.